TransNova SOC Console Guide

Every screen, what it offers, and what its data means.
For analysts and for the judges watching the demo.

Three-honeypot Security Operations Center: web, MariaDB and Cowrie SSH decoys · React + FastAPI console · Screenshots show live lab data from 2026-11-01

The three ideas behind every screen

1. Event. One stored record of something a honeypot observed: a page view, a login attempt, a SQL query, a shell command. Events are evidence and are **never edited**.

2. Rule match. A detection rule looked at the event and found something of interest. Some rules are *signal only*: a single failed login is noted but never opens an alert.

3. Alert. Opens only when a rule's documented condition is met, such as 5 failed logins in 60 seconds. There is **one alert per rule per source**; repeat activity updates the existing alert instead of creating duplicates.

Everything an analyst decides (a status, a note, a reclassification, an AI explanation) is stored **beside** the evidence with the analyst's name and the time. Nothing on screen is hardcoded: every number comes from stored data, and empty or unavailable states say so honestly.

An event is not an alert, and an alert is not a confirmed incident. One wrong password is an event. A shared IP across honeypots is a lead, not proof of one actor.

How data flows

Honeypot interaction → sensor normalises and redacts → collector validates and stores it (before replying) → detection rules evaluated → correlation → alert opened or updated → visible in All events, the source profile and Alerts. Open consoles receive a change notice within about 2 seconds.

Container	Role
web-decoy	Web honeypot; reports its own events
database-honeypot + db-sensor	MariaDB honeypot; the sensor reads the audit log and sends events
ssh-honeypot + ssh-sensor	Cowrie SSH honeypot; the sensor reads Cowrie's log and sends events with its own token
collector	Receives, stores, detects, correlates and serves the data
console	The SOC dashboard at http://127.0.0.1:8501

Each honeypot runs in its own container on an isolated network, so a breakout from one reaches neither the others nor the SOC.

The rail (left sidebar)

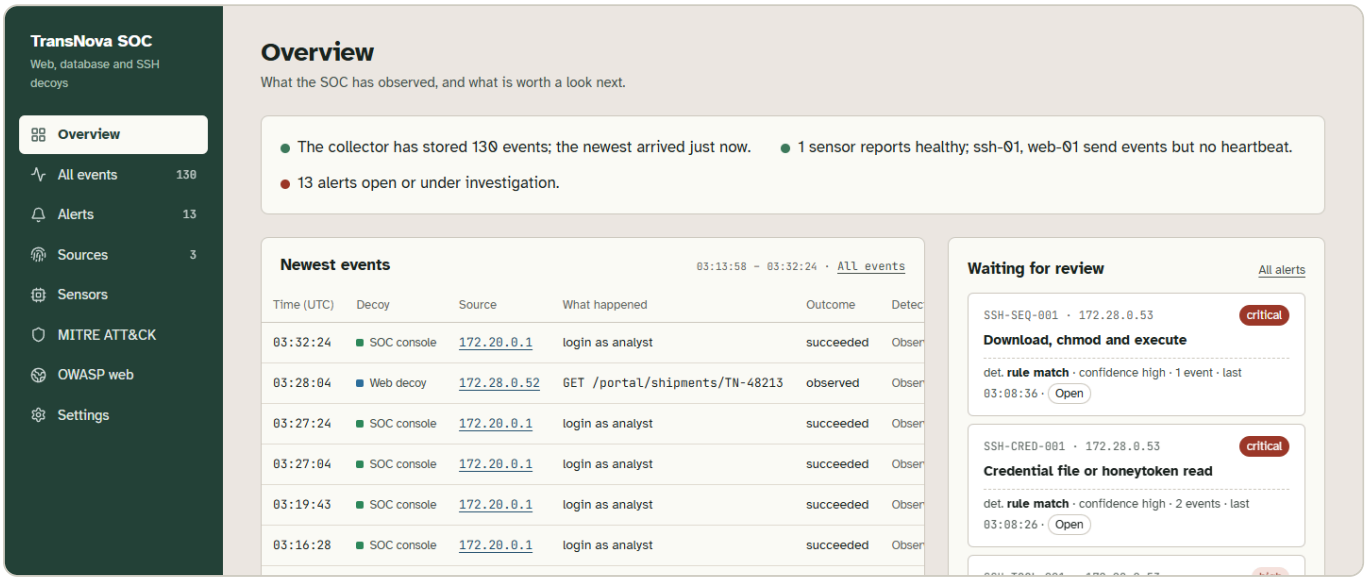
- **Page links with live counts:** total events stored, alerts open or under investigation, and addresses observed.
- **Live status:** *Live updates on* (new data appears without a refresh), *Connecting…*, or *Live updates off, refreshing every 10 s*.
- **Your username, role and Sign out.** Signing out is itself recorded as an event.

01 Sign in

- Every attempt is recorded as a **SOC console** event: success, failure, sign-out, session expiry and rate limiting.
- One wrong password is an event, not an attack. **Five failures in 10 minutes** from one source, or against one username, opens a medium **Repeated failed SOC console logins** alert.
- After 10 failures in 10 minutes, sign-in is refused for that source for a while, and that refusal is recorded too.
- Passwords are never stored or logged, only whether the attempt succeeded.

02 Overview

Answers four questions: is the SOC working, does anything need attention, are the sensors healthy, what should I look at next?



- **State strip, in sentences.** Collector: events stored and when the newest arrived. Sensors: how many report healthy and which send no heartbeat. Alerts: how many are open or under investigation (red dot if any are high or critical, amber otherwise, green if none). Ingest refusals appear only when the collector rejected sensor data.
- **Newest events.** The latest 8. The grey timestamps at the top right show the span on screen. A **brass dot** marks events new since your last visit.
- **Events in the last 24 hours.** A stacked bar per UTC hour, coloured by honeypot: web database SSH console. Hover for exact counts; an empty hour is genuinely zero.
- **Waiting for review.** The most important open alerts, shown as *determination slips*.

SSH-SEQ-001 · 172.28.0.53 critical

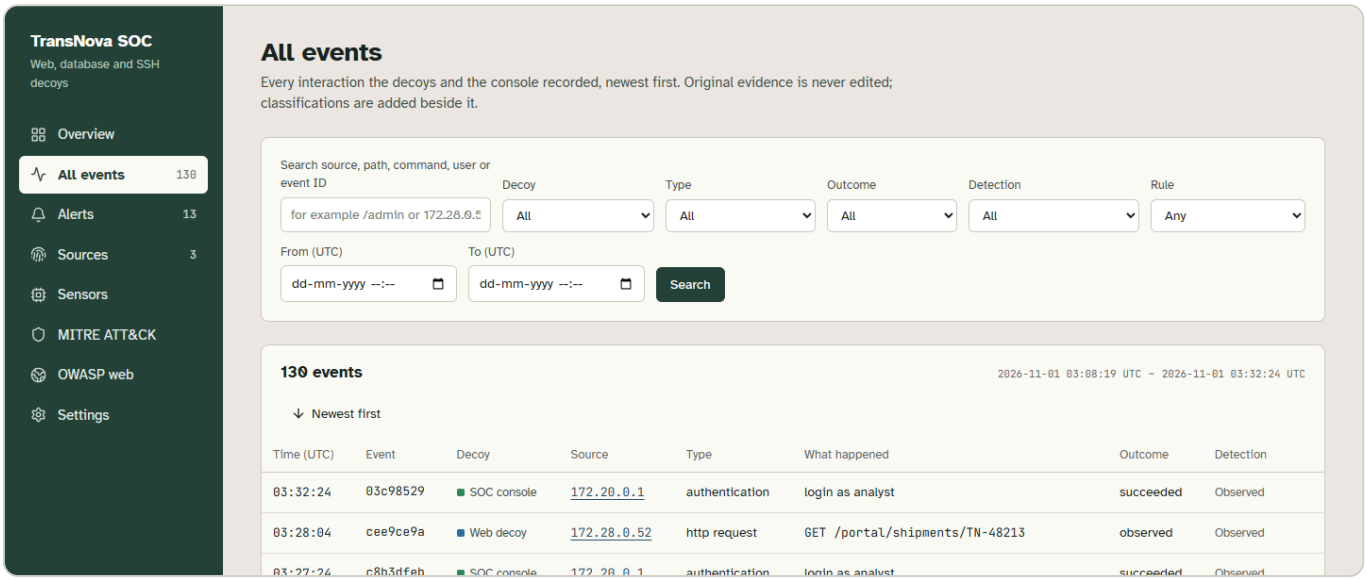
Download, chmod and execute

det. rule match · confidence high · 1 event · last 03:08:36 · Open

How to read a slip: rule ID and source, then the alert title, then the determination line.

03 All events

Every stored interaction from all three honeypots plus console sign-ins, newest first, 50 per page.



Filters (applied on the server, so they scale)

- **Search:** source address, action, path, command, username or event ID.
- **Decoy, Type, Outcome, Rule:** dropdown counts come from real stored data.
- **Detection:** *Observed only* (no rule matched), *Rule matched, no alert* (threshold not met, or a signal-only rule), *In an alert* (evidence for at least one alert).
- **From / To:** a time range in UTC. Active filters appear as removable chips; "Newest first" flips the order.

Column	Meaning
Time (UTC)	When the honeypot observed it; brass dot = new since your last visit
Event	First 8 characters of the unique event ID
Decoy	Which honeypot, or the SOC console
Source	Network address it came from; click for the source profile
Type	http request, authentication, sql query, command, connection, file transfer
What happened	One-line summary from the event: `GET /admin`, the SQL, the command, "login as jdoe"
Outcome	observed, succeeded, failed, or **blocked** (the server denied it)
Detection	Observed / Rule matched / In an alert, plus any analyst classification

Database note: when the MariaDB client connects, it sends `select @@version_comment`, `show databases` and `show tables` by itself. The honeypot records what really reached the server, including traffic the tool sends on its own.

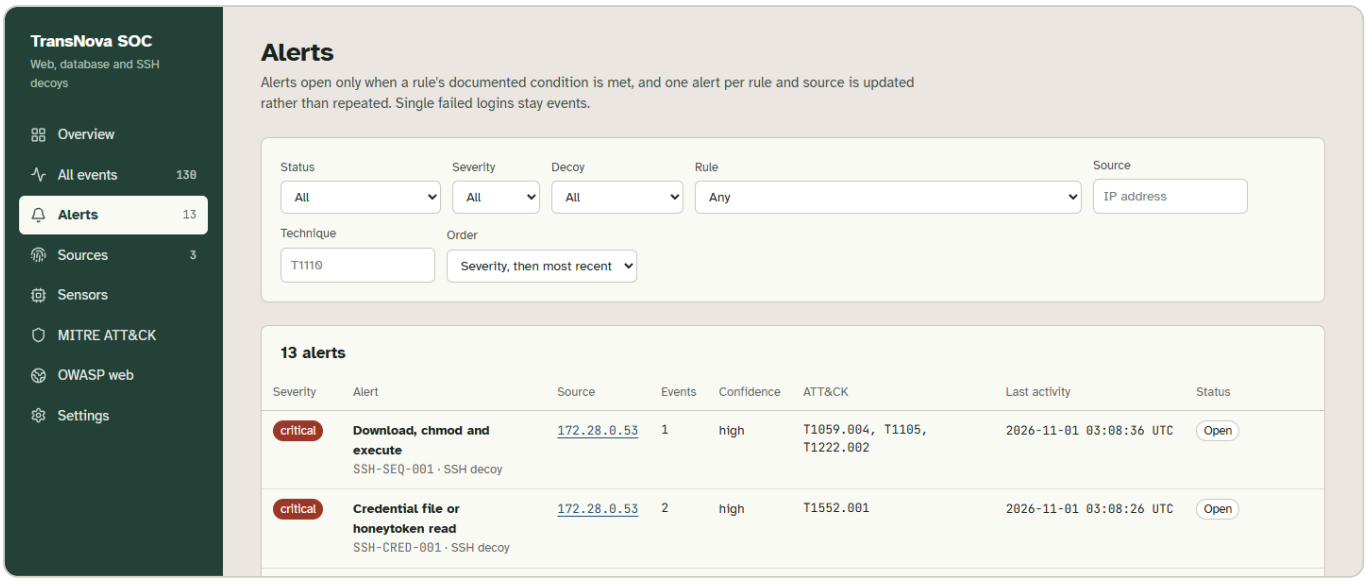
03b Event detail



- **Observation:** every recorded field: exact time, source port, sensor, session ID (click to filter to that session), request with HTTP status, command or query, tables touched, user agent.
- **Raw evidence:** the sensor's redacted record exactly as stored, shown as plain text, so a `<script>` payload displays harmlessly and never runs.
- **This session** and **Recent events from the same source**.
- **Determination:** each rule that matched, with rationale, confidence, whether it can open an alert, OWASP category and ATT&CK technique. Analyst classification slips stack below.
- **Add a classification** (analysts only): Benign, Suspicious, Confirmed malicious, False positive or Unclassified, with a required reason. It adds a slip and never changes the event.
- **Alerts that include this event.**

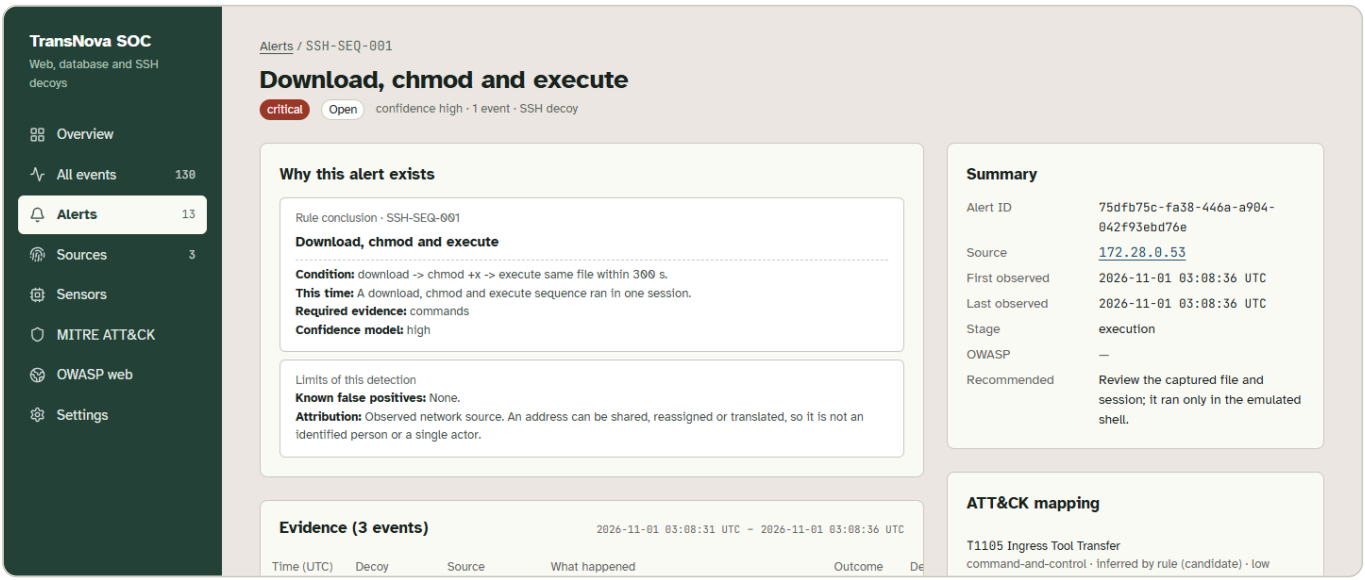
04 Alerts

The triage list, sorted by severity then most recent (switchable to most recent activity). Filters: status, severity, decoy, rule, source and ATT&CK technique.



Column	Meaning
Severity	critical high medium low. Red appears only for high and critical.
Alert	Title, rule ID and honeypot
Source	Address the activity came from
Events	How many events have fed this alert
Confidence	How sure the rule is, based on the strength of its evidence
ATT&CK	Technique IDs the rule maps to
Last activity	Most recent supporting event
Status	Open, Under investigation, Confirmed malicious, False positive, Resolved. "New activity since" = events arrived after it was closed

04b Alert detail



Left column: investigation

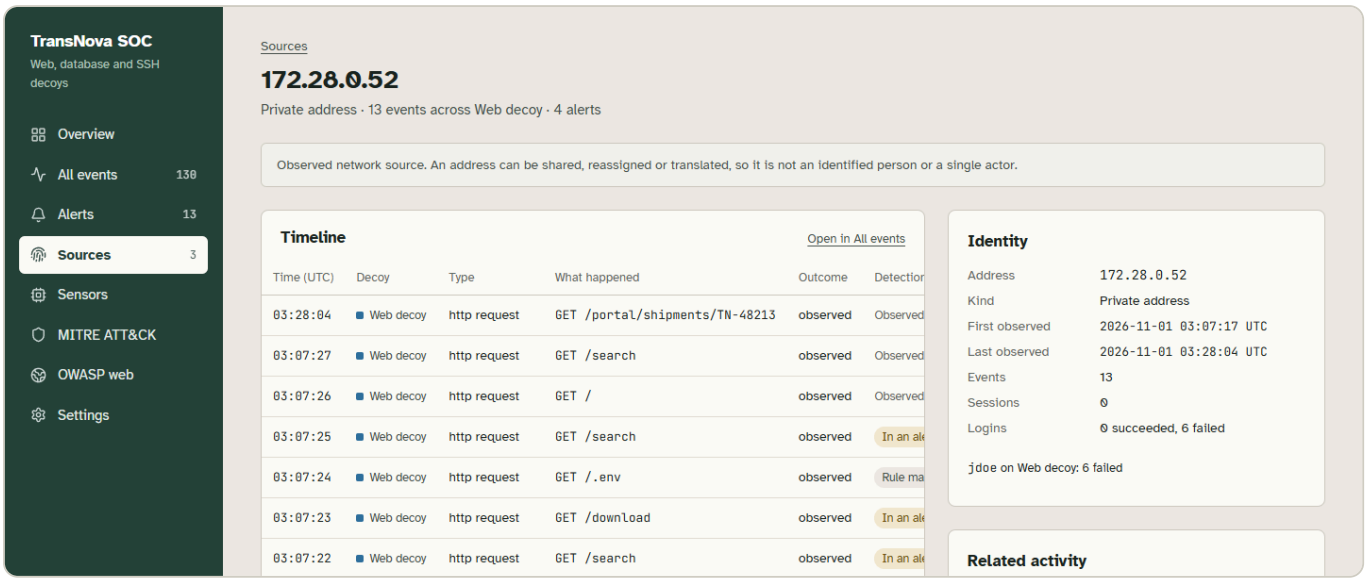
- **Why this alert exists.** *Rule conclusion:* the condition, what happened this time, the evidence the rule needs, how confidence is decided. *Limits of this detection:* known false positives, what the rule cannot establish, and a reminder that an address is not a person.
- **Evidence:** the linked events and their time window, including the earlier events that led up to a threshold alert (all 5 failed logins).
- **Matched rule conditions:** per-event rationale and the field that matched.
- **Explainable AI:** Claude explains from stored evidence only, split into observed facts (with event IDs), the rule's conclusion, an interpretation marked *not verified*, benign explanations, supporting and weakening evidence, what can't be established, and safe next steps. It can never change the alert. Without an API key it says "not configured".

Right column: decisions

- **Summary:** alert ID, source, first and last observed, attack stage, OWASP, recommended action.
- **ATT&CK mapping:** each technique with name and tactic. *Supported by evidence* = observed directly; *inferred by rule (candidate)* = suggested but not proven.
- **Disposition** (analysts): Start investigating, Confirm malicious, Mark false positive, Resolve, Reopen, Add note only. Confirming or marking a false positive requires a reason.
- **Investigation history:** who, when, from which status to which, and the note.

05 Sources

Every network address the honeypots observed (console sign-ins stay in All events). Columns: source, kind (private, public, loopback, or "session with no address"), honeypots touched, events, sessions, alerts, first and last seen.

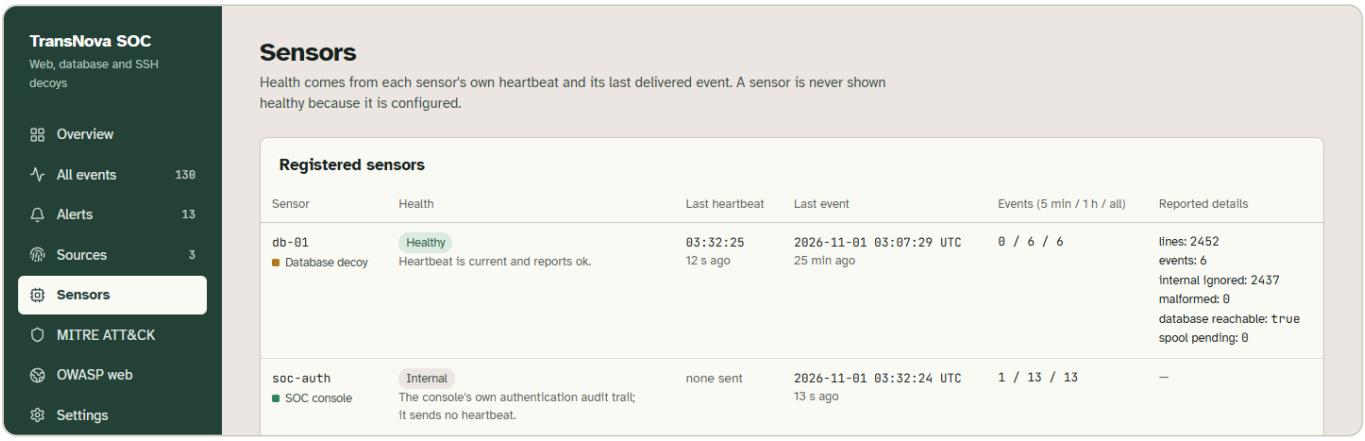


Source profile

- **Attribution notice:** an address can be shared, reassigned or translated, so it is not an identified person.
- **Timeline:** every event from that address, paginated.
- **Sessions:** session ID, honeypot, username, event count, start time. **Bar length is the real session duration**, relative to the longest shown.
- **Commands seen, Database statements, Web requests:** what was actually typed or requested.
- **Identity:** address, kind, first and last observed, login successes and failures, usernames tried per honeypot.
- **Related activity** (correlation rules, each with confidence and reason): *C-XSVC-01, low*: same address on two honeypots within 30 minutes, a lead not proof. *C-CAMP-01, high*: traffic labelled by the lab simulator. Session links are summarised in one line.
- **Techniques observed:** ATT&CK techniques linked to their events, marked evidence or rule-inferred. Tool names are deliberately not guessed.
- **Alerts** involving this source.

06 Sensors

Operational health. A sensor is never shown healthy just because it is configured.

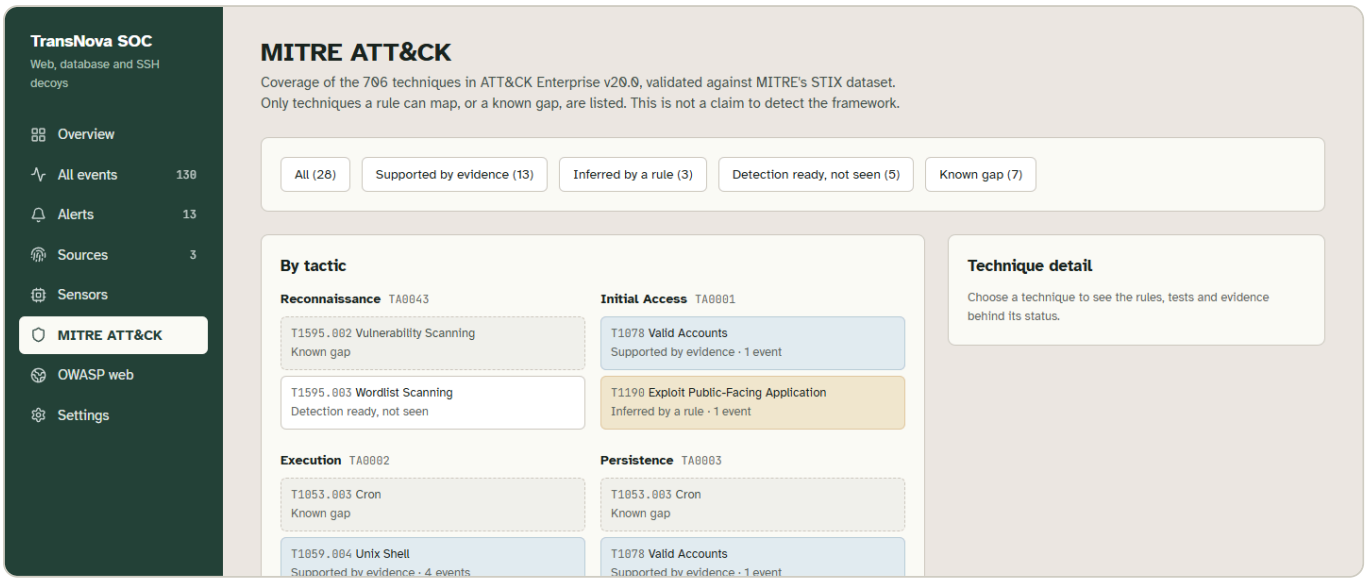


Column	Meaning
Sensor	`web-01`, `db-01`, `ssh-01`, or `soc-auth` (the console's audit trail)
Health	**Healthy**: current heartbeat reporting ok · **Degraded**: sensor says so itself · **Stale**: no heartbeat for over 45 s · **Health unknown**: sends events but no heartbeat · **Internal**: console trail
Last heartbeat	Only db-01 sends heartbeats
Last event	When its newest event arrived
Events (5m / 1h / all)	Throughput
Reported details	What the sensor reports about itself (database reachability, spool backlog)

- **Not heard from:** an expected sensor that has sent nothing.
- **Ingestion refusals:** sensor data rejected since the collector started, with the reason. Refused reads and analyst actions are listed separately.
- **Adaptive deception:** database decoy tables revealed in response to attacker behaviour, the trigger, and whether the attacker then read them.
- **Live sessions** reported by the database sensor.

07 MITRE ATT&CK

Coverage against the official ATT&CK Enterprise v20.0 dataset (706 techniques). Only techniques a rule can map, or known gaps, are listed. This is not a claim to cover the framework.

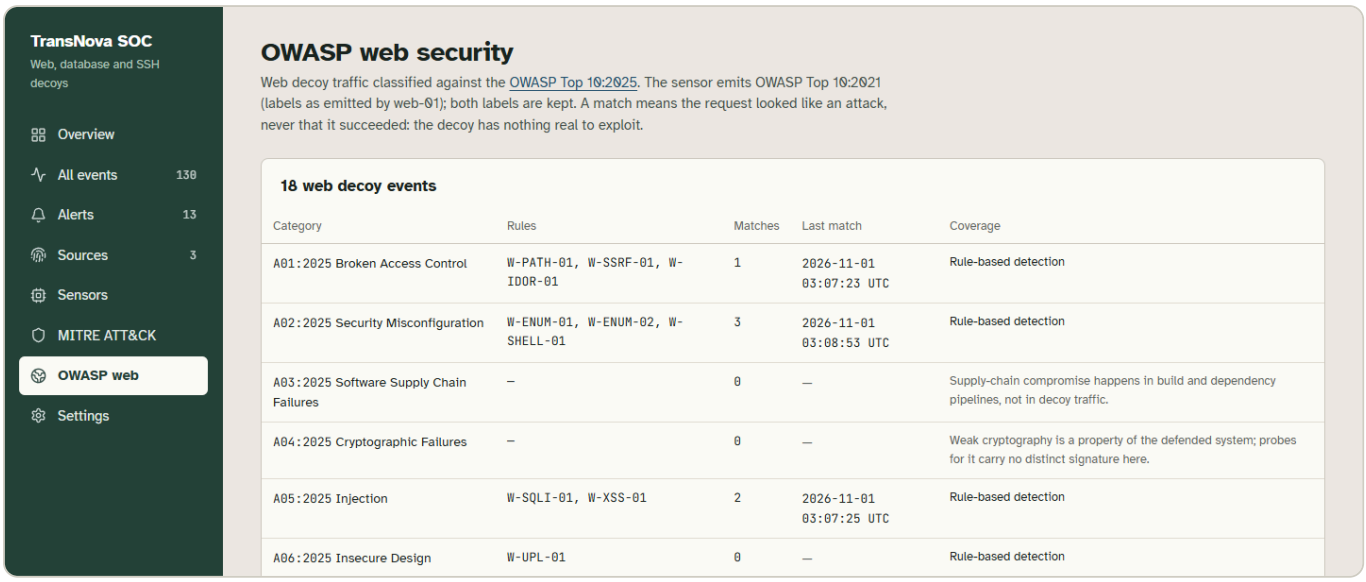


Card	Status	Meaning
Blue	Supported by evidence	A sensor observed the technique directly in stored events
Amber	Inferred by a rule	A rule matched and suggests it; the evidence doesn't prove it
White	Detection ready, not seen	A rule exists; nothing has triggered it yet
Dashed	Known gap	Plausible for these honeypots, but no rule detects it (port scans, crontab edits)

Filter buttons show counts per status. Techniques are grouped by tactic; one technique can appear under several. Clicking one shows its tactics, honeypots, rules, which rules have tests, event counts (observed versus candidate), alerts, a link to attack.mitre.org, the gap reason, and "Show the events". AI explanations never add a mapping here.

08 OWASP web

Web honeypot traffic classified against the **OWASP Top 10:2025**, keeping the 2021 label the web sensor originally sent.



- **Category table:** all 10 categories with rules, match count and last match. *Rule-based detection* means covered; *Not observable* means honeypot traffic can't show it, and the reason is given (supply chain, cryptography, logging failures).
- **Main categories you'll see:** A05 Injection (SQL injection, XSS) · A01 Broken Access Control (path traversal, object-ID tampering, SSRF) · A07 Authentication Failures (failed and brute-force logins) · A02 Security Misconfiguration (probes for `.env`, `.git`, admin paths).
- **Clicking a category** lists the matching requests and each rule's logic, evidence, false positives and limits.

A match means the request looked like an attack, never that it succeeded. The decoy has nothing real to exploit.

09 Settings

Read-only configuration status; nothing is edited from the browser.

- **Your account:** username, role, whether you can change alerts, idle sign-out time.
- **Connections:** collector reachability, read token present and accepted, analyst-action token present, number of accounts, sign-in audit backlog, cookie and session settings. Secrets show only as *present* or *missing*, never their values.
- **AI explanations:** provider, model, configured or not.
- **Detection content:** rule counts, which can alert, which are signal-only, ATT&CK version, OWASP edition.

Roles

- **Viewer:** sees everything; cannot change alerts or classify events.
- **Analyst and admin:** can take every action, each recorded under their name.